

Chapter 13. Security Requirements

13.1. Overview

Each Matter security and privacy requirement references the underlying countermeasure (CM) and threat (T) in the Threat Model that motivated the need for the requirement. The requirements are grouped by topic. Unless stated otherwise, these requirements typically address all Devices and Nodes (i.e. all implementations of Matter functionality). Some requirements are called out specifically for a particular group of implementations, or Roles.

13.2. Device vs. Node

For some requirements, we need to differentiate between a Node (the entity which supports the Matter protocol stack) and a Device (a piece of equipment containing one or more Nodes).

- If the Node contains all of the Matter functionality, nevertheless it will probably rely on some security features of the Device.
- If the Node uses Matter functionality provided by the Device, the requirements obviously hold for both the Node and the Device.

13.3. Commissioning

- a. Nodes SHALL stop both commissioning and unsecured rendezvous actions after a specified time period from the beginning of the commissioning mode when commissioning has not been concluded, unless allowed for other purposes such as [Commissionable Node Discovery](#). The time period for commissioning and unsecured rendezvous announcements SHALL follow requirements as specified in [Section 5.5, “Commissioning Flows”](#) and [Section 5.4.2.3, “Announcement Duration”](#) respectively. [CM8 for T5, T7]
- b. Nodes SHALL utilize multiple hash iterations in PBKDF, as required by definitions in [Section 3.9, “Password-Based Key Derivation Function \(PBKDF\)”](#). Nodes SHALL validate the bounds of the iteration count for PBKDF, to respect the minimum and maximum values stated in the cryptography primitives section (see [Section 3.9, “Password-Based Key Derivation Function \(PBKDF\)”](#)). [CM99 in T102]
- c. Nodes SHALL exit commissioning mode after 20 failed commission attempts (see [Section 5.5, “Commissioning Flows”](#)). [CM100 for T101, T112]
- d. Devices SHALL include a Device Attestation Certificate and private key, unique to that Device. [CM23 for T22, T24, T34, T86]
- e. If an [NFC Tag](#) is used to convey the Onboarding Payload from a device to a Commissioner, the NFC Tag SHALL only allow the alteration of the Onboarding Payload and the reading thereof in ways and in device states which attackers cannot exploit to surreptitiously commission the device. For example, the NFC Tag Onboarding Payload is protected from modification outside of manufacturing, or the NFC tag read-out is impossible when the device is still in its original packaging. [CM4 for T90]
- f. The Commissioner or Administrator completing the commissioning, after the first phase has